Comme expliqué précédemment:

- une AIPD est requise lorsque le traitement «*est susceptible d'engendrer un risque élevé pour les droits et libertés des personnes physiques*» [article 35, paragraphe 1; voir III, B, a)]. À titre d'exemple, le traitement de données de santé à grande échelle est considéré comme susceptible d'engendrer un risque élevé et nécessite une AIPD;
- dès lors, il appartient au responsable du traitement d'évaluer les risques pour les droits et libertés des personnes concernées et d'identifier les mesures[29] envisagées pour réduire ces risques à un niveau acceptable et apporter la preuve du respect du RGPD [article 35, paragraphe 7; voir III, C, c)]. Par exemple, dans un cas de stockage de données à caractère personnel sur ordinateurs portables, l'application de mesures de sécurité techniques et organisationnelles appropriées (chiffrement efficace et complet des disques, gestion des clés rigoureuse, contrôle approprié des accès, sauvegardes sécurisées, etc.) en plus des règles existantes (avis, consentement, droit d'accès, droit d'opposition, etc.).

Dans l'exemple des ordinateurs portables ci-dessus, à condition que les risques aient été jugés suffisamment réduits par le responsable du traitement et après prise en compte de l'article 36, paragraphe 1, et des considérants 84 et 94, le traitement pourrait être mis en œuvre sans consultation de l'autorité de contrôle. Ce n'est que lorsque les risques identifiés ne peuvent pas être suffisamment réduits par le responsable du traitement (à savoir en présence de risques résiduels élevés) que ce dernier est tenu de consulter l'autorité de contrôle.

Un risque résiduel peut notamment être considéré comme élevé et inacceptable dès lors qu'il exposerait les personnes à des conséquences importantes, voire irréversibles, qu'elles seraient susceptibles de ne pas pouvoir surmonter (par ex:. un accès illégitime à leurs données qui pourrait menacer leur vie, entraîner une mise à pied, mettre en péril leur situation financière) et/ou lorsqu'il semble évident que le risque se concrétisera (par ex.: dans la mesure où il n'est pas possible de réduire le nombre de personnes accédant aux données en raison de leurs modes de partage, d'utilisation ou de distribution, ou en présence d'une vulnérabilité bien connue non corrigée).

Lorsque le responsable du traitement ne parvient pas à identifier des mesures suffisantes pour réduire les risques à un niveau acceptable (à savoir que les risques résiduels demeurent élevés), une consultation de l'autorité de contrôle est obligatoire[30].

En outre, l'autorité de contrôle devra être consultée dans tous les cas où le droit de l'État membre exige que les responsables du traitement consultent l'autorité de contrôle et/ou obtiennent son autorisation préalable en ce qui concerne un traitement que le responsable du traitement envisage dans le cadre d'une mission d'intérêt public dont il est investi, notamment pour les traitements en rapport avec la protection sociale et la santé publique (article 36, paragraphe 5).

[29] En tenant également compte des orientations existantes du CEPD et des autorités de contrôle, ainsi que des possibilités techniques les plus récentes et des coûts de mise en œuvre, comme prévu à l'article 35, paragraphe 1.

[30] Remarque: «*la pseudonymisation et le chiffrement des données à caractère personnel*» (tout comme la minimisation des données, les mécanismes de contrôle, etc.) ne sont pas nécessairement des mesures appropriées. Il ne s'agit là que d'exemples. Les mesures appropriées dépendent du contexte et des risques spécifiques aux opérations de traitement.